

Smart Contract Audit Report, consolidated

Apyee Protocol **V2**

Immutable ERC-4626 USDC Vault

Three audit rounds on one codebase: the initial audit at tag v2.0.0, the review of the remediation and of the new reward-claim surface at v2.1.1 and v2.1.2, and the residual review of the deployed generation at v2.1.3. This edition consolidates all three, states the final disposition of every finding, and reports the state of the live deployments on four chains as re-read on 22 September 2026.

FINAL STATUS AT V2.1.3 **PASS, 91 / 100**

PREPARED BY SOKEN LTD, Smart Contract Security	REPORT IDS CONSOLIDATED APY-2026-06-001, APY-2026-06-002, APY-2026-06-002-B
AUDIT PERIOD June to July 2026, last report 9 July 2026	FIGURES RE-VERIFIED 22 September 2026
SCOPE VaultV2 plus BaseStrategy and five adapters	NETWORKS Ethereum, Base, Arbitrum, BNB Chain
AUDITED TAGS v2.0.0, v2.1.1, v2.1.2, v2.1.3 (commit e737779)	FINDINGS ACROSS THE CYCLE 1 Critical, 0 High, 2 Medium, 4 Low, 9 Informational, plus 11 round-two items

SOKEN LTD. Security review of the source code and of the deployed bytecode. Not financial, investment or legal advice. See the disclaimer in section 09.

01 Executive summary

Apyee Protocol V2 is an immutable ERC-4626 vault that routes USDC into blue-chip lending markets through whitelisted strategy adapters, with a streaming performance fee that accrues on share-price growth. The vault is not upgradeable: a change of logic means a redeploy, so every defect found before launch matters more than usual.

The first round found one Critical defect. A vault that had reached zero total supply carried a stale fee baseline, and the next deposit made the measured share price jump far enough to trip the fee guard, after which every deposit, withdraw, redeem and accrual reverted. The trigger needed no privilege and cost about ten wei of USDC plus gas, and the result was a permanent freeze of whatever the vault held. Two Medium findings followed: the accrual hook ran after OpenZeppelin had already priced a deposit or withdrawal, so both sides were mis-priced, and re-adding a previously removed strategy pushed a duplicate entry into the strategy list and double-counted its balance in total assets.

All sixteen round-one findings were remediated or accepted with reasons. The remediation introduced a reward-claim path, which we audited as a new surface in round two and which produced eleven further items, from a missing on-chain slippage floor on reward swaps to build-pipeline drift between the two toolchains. Round three verified the last residuals on the exact tag that is deployed today.

- **Score trajectory across the cycle.** 55 out of 100 at v2.0.0, 78 at v2.1.1, 88 at v2.1.2 and 91 at v2.1.3, where the remaining gap is trust-model surface that is documented rather than an open defect.
- **Everything reported as fixed is present in the deployed code.** Re-checked line by line at tag v2.1.3, not taken from the client's remediation notes.
- **The deployed contracts are the audited contracts.** Four of the five production vaults have explorer-verified source that matches the v2.1.3 tag exactly apart from import-path depth; the fifth, on BNB Chain, has no reachable verifier service, and its bytecode matches the verified Ethereum deployment to within the embedded asset address and metadata hash.
- **Independent reproduction.** The Critical and both Medium findings were reproduced again on 22 September 2026 against the real v2.0.0 contracts, returning the same figures the original report published.

16 + 11

FINDINGS ACROSS THREE ROUNDS

1

CRITICAL, FIXED BEFORE LAUNCH

0

OPEN CRITICAL, HIGH OR MEDIUM

91 / 100

SECURITY SCORE AT V2.1.3

5

PRODUCTION VAULTS, FOUR CHAINS

4 of 5

VERIFIED SOURCE MATCHING THE TAG

Two facts a reader should keep in view. The vault holds nominal amounts today: total assets read between 0.002 and 1.28 USDC across the five deployments on 22 September 2026, which is a soft launch rather than a funded protocol. And the Owner role, a Gnosis Safe, can whitelist a strategy of its own making and route principal through it; that is an accepted centralisation property of the design, disclosed in the project's trust model and restated in section 06.

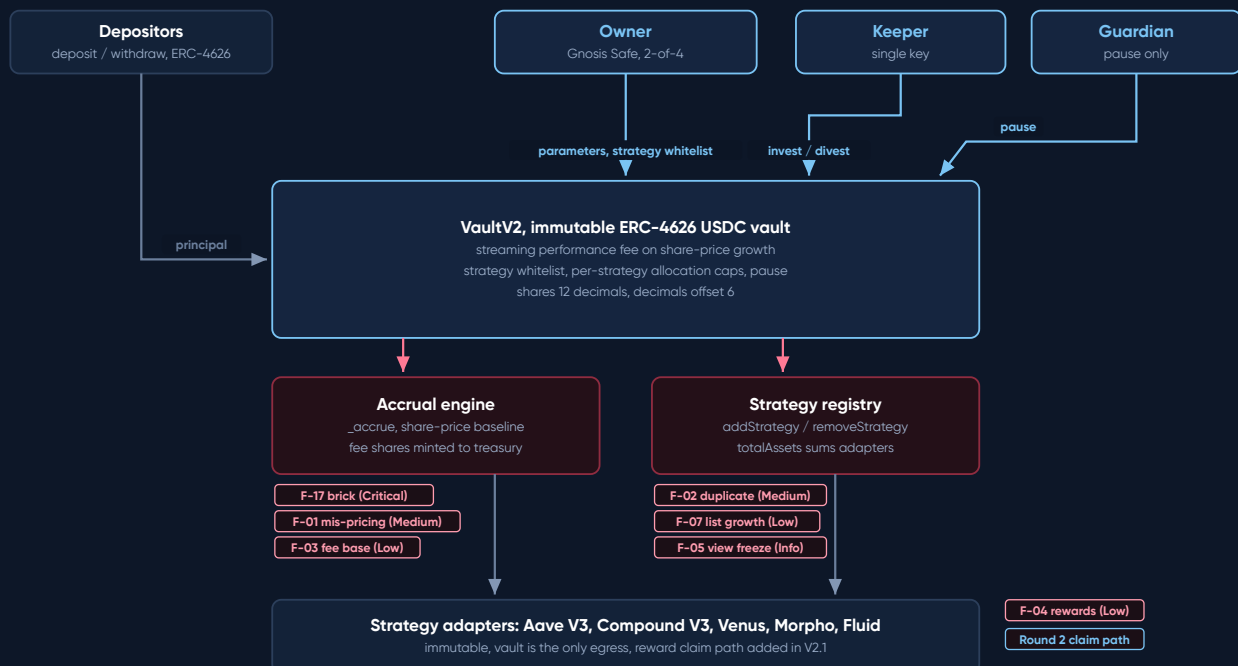
02 Scope and method

AREA	WHAT WE DID
------	-------------

Code in scope	contracts/Vault.sol (VaultV2), contracts/strategies/BaseStrategy.sol and the five adapters for Aave V3, Compound V3, Venus, MetaMorpho and Fluid, plus interfaces/IStrategy.sol and libraries/Errors.sol. Mocks, tests, scripts and deployment tooling were out of scope. Solidity 0.8.28, OpenZeppelin 5.x, non-proxied.
Rounds and tags	Round 1 at v2.0.0 (887 lines in the vault), round 2 at v2.1.1 and v2.1.2, round 3 at v2.1.3 (1,076 lines). One audited source compiles to one runtime per tier, differing only in the immutable allocation cap and a version hash, so a single audit covers the tier matrix.
Manual review	Line-by-line review of the vault and every adapter against the OpenZeppelin 5.x ERC4626, Ownable2Step and Pausable bases, with particular attention to the accrual hook, the strategy lifecycle, the total-assets path and, in round two, the reward-claim and swap path.
Static analysis	Slither 0.11.5 and Aderyn across the tree, with every hit triaged to a finding, a known design decision or a false positive.
Proof of concept	Foundry harnesses against the real contracts for the Critical and both Medium findings, plus the fee-formula finding. Re-run on 22 September 2026: the brick reverts with FeeTooHigh (1500, 2000) on every state-changing path, a 100,000 USDC deposit is immediately worth 99,086.16 USDC at the fee ceiling, a duplicate strategy re-add reports 140,000 USDC of total assets against 100,000 USDC of real assets, and a 15 percent fee collects 164.999999 USDC where 150.00 USDC is due.
Re-verification, September 2026	Every citation in the three published reports was re-checked at the audited tag; the fix status of every finding was re-checked at v2.1.3; the five production vaults, the Owner Safe on four chains and the retired generation were read on-chain; source identity was checked through Sourcify and Blockscout. Corrections are listed in section 08 and the full record travels with this report.

03 Architecture and where the findings sat

VaultV2, its roles, and the location of each material finding



Blue edges are privileged calls, grey edges are user funds and internal routing. Red labels mark the finding that lived in that component at v2.0.0. Every one of those findings is closed in the code that is deployed today.

ROLE	POWER, AS IMPLEMENTED
Owner	All parameter setters plus unpause. Held by a Gnosis Safe at address <code>0xEC4d3B...92A98e</code> , threshold 2, with four signers on Ethereum, Base and BNB Chain and three on Arbitrum. The Owner can whitelist a strategy and route principal into it, so the Owner is a trusted role by design.
Keeper	Single key <code>0x84c00e...4FA12c</code> . Moves funds between the vault and whitelisted strategies only, subject to per-strategy caps, and drives the reward-claim path added in V2.1.
Guardian	Single key <code>0xD94321...6Aaac1</code> , pause only. Unpause is deliberately Owner-only, so one key cannot resume the system after an emergency.
Depositors	Standard ERC-4626 rights. Withdraw and redeem carry no pause modifier, so exit stays open even while deposits are paused.

Properties confirmed in the code rather than assumed: the only mint to the treasury is the streaming fee, gated on genuine share-price growth and bounded by a 2000 basis point ceiling; fee-rate and treasury changes accrue first, so a rate change is not retroactive and a treasury swap cannot capture pending fees; the deposit-side inflation attack is mitigated by a decimals offset of six; and no non-Owner role has a path that moves principal to an arbitrary address.

04 Round one findings at v2.0.0

ID	FINDING	SEVERITY	STATE AT V2.1.3
F-17	Permanent vault brick via stale lastSharePrice after totalSupply() returns to zero	■ CRITICAL	■ FIXED AT V2.1.3
F-01	Accrual hook-ordering mis-prices deposits and withdrawals (preview not mirrored)	■ MEDIUM	■ FIXED AT V2.1.3
F-02	Re-adding a removed strategy duplicates it in strategyList, double-counting totalAssets()	■ MEDIUM	■ FIXED AT V2.1.3
F-03	Streaming fee over-charges by factor (1+g): fee base is post-yield totalAssets()	■ LOW	■ FIXED AT V2.1.3
F-04	Protocol reward tokens (COMP / XVS / MORPHO / Fluid) accrue to adapters and are never claimed	■ LOW	■ FIXED AT V2.1.3
F-06	Single-step Ownable (not Ownable2Step)	■ LOW	■ FIXED AT V2.1.3
F-07	strategyList grows unbounded across the strategy lifecycle	■ LOW	■ FIXED AT V2.1.3
F-05	Unguarded strategy balanceOf() in totalAssets() can freeze deposits and withdrawals (future adapter)	■ INFORMATIONAL	■ FIXED AT V2.1.3
F-15	Unused custom errors (StrategyBlacklisted and three others) - dead code	■ INFORMATIONAL	■ FIXED AT V2.1.3

Nine further findings were Informational. Severity distribution for the round: 1 Critical, 0 High, 2 Medium, 4 Low, 9 Informational, sixteen counted findings in total. A positive coverage note, recorded as F-16, verified that no role other than the Owner can move user principal to an arbitrary address.

F-17 Permanent vault brick via stale lastSharePrice after totalSupply() returns to zero

■ CRITICAL

Location at v2.0.0. contracts/Vault.sol:432-434 (FeeTooHigh guard), 387-457 (_accrue), 489-511 (_deposit), 517-528 (_withdraw); lazy re-init at 402 and 508

lastSharePrice is the fee baseline and is never reset to 0 when totalSupply() returns to 0. Because withdraw and redeem carry no pause modifier, any set of depositors can unprivilegedly drain the vault to zero supply. A subsequent re-seeding deposit, combined with a donation of approximately 10 wei USDC or more, produces an apparent share-price jump of roughly 924x against the stale baseline. This trips the FeeTooHigh guard on the next fee accrual, and because every deposit, withdraw, redeem, accrue, setFeeRate, and setTreasury call runs accrual first, the vault becomes permanently unusable through its standard adapters and admin functions. Independently reproduced with a fresh Foundry harness against the real v2.0.0 bytecode: accrue(), redeem(), and setFeeRate(0) all revert with the exact selector FeeTooHigh(1500,2000) after the brick sequence.

Recommendation. Reset lastSharePrice to 0 whenever totalSupply() returns to 0, for example in _withdraw immediately after the post-burn supply check, so the next deposit re-takes the lazy-init path and re-snaps the baseline cleanly.

Resolution. Fixed at v2.1.3 exactly as recommended, confirmed by direct source inspection at both reset sites. Note: the original report's claim of no in-contract recovery path is overstated - a trusted Owner could technically unbrick the v2.0.0 vault without redeploying by whitelisting a strategy contract that deliberately misreports its balance, though this is not a safe or sanctioned mechanism and relies on the same Owner-trust boundary already disclosed in F-16.

F-01 Accrual hook-ordering mis-prices deposits and withdrawals (preview not mirrored)

■ MEDIUM

Location at v2.0.0. contracts/Vault.sol:489-511 (_deposit), 517-528 (_withdraw), 387-457 (_accrue)

OpenZeppelin's ERC4626 prices deposits and withdrawals via previewDeposit/previewWithdraw before the _deposit/_withdraw hook runs. Because the fee-share mint happens inside that hook, the deposit is priced against the pre-accrual pool but settled against the post-accrual (diluted) pool, so depositors receive fewer shares than fair value and withdrawers extract more than their fair share. Independently reproduced with a fresh Foundry harness: at feeRate 2000bps with a 5% un-accrued yield gap and a 1-day time advance, a 100,000 USDC deposit is immediately redeemable for approximately 99,086.16 USDC, matching the report's reproduction figure to the dollar; at 1500bps the figure is approximately 99,314.77 USDC, also matching.

Recommendation. Accrue before shares are priced, either by overriding deposit/mint/withdraw/redeem to call _accrue() before delegating to super, or by mirroring the pending fee-share mint inside the preview* functions per ERC4626.sol's own documented requirement.

Resolution. Fixed at v2.1.3 via the first approach (accrue-first override on all four public entrypoints), confirmed present in source. A follow-up view-side gap (maxWithdraw/previewWithdraw not reflecting pending accrue) was separately identified and fixed as Fix #9 in v2.1.2/v2.1.3, documented in docs/SOKEN_AUDIT.md section 11.3.9.

F-02 Re-adding a removed strategy duplicates it in strategyList, double-counting totalAssets()

MEDIUM

Location at v2.0.0. contracts/Vault.sol:693 (addStrategy push), 720-729 (removeStrategy, no array removal), 581-592 (totalAssets sum), 676 (re-add guard checks flags only)

removeStrategy clears the isActive and isBlacklisted flags but never removes the address from the iterable strategyList, and addStrategy's re-add guard checks only those flags rather than list membership. A strategy removed and then re-added ends up listed twice while strategyInfo is a single per-address record, so totalAssets() sums its balance twice. Independently reproduced: after add, remove, and re-add of the same strategy, strategyCount() reads 2, and after a \$100k deposit with \$40k invested, totalAssets() returns exactly \$140,000 instead of \$100,000, matching the report's worked example precisely. This is an ordinary, non-malicious admin lifecycle action (rotate a strategy out for maintenance, then back in), reachable only by the trusted Owner, not by any unprivileged party.

Recommendation. Swap-and-pop the address out of strategyList inside removeStrategy, or track an everListed flag in addStrategy and reuse the existing slot instead of pushing a duplicate entry.

Resolution. Fixed at v2.1.3 via swap-and-pop in removeStrategy, confirmed present in source; the fix also resolves F-07 (unbounded list growth) as a side effect, as claimed.

F-03 Streaming fee over-charges by factor (1+g): fee base is post-yield totalAssets()

LOW

Location at v2.0.0. contracts/Vault.sol:417-422 (_accrue fee computation), 472-477 (_feeSharesFor)

The fee formula multiplies the growth-rate delta by the current (post-yield) totalAssets() rather than the asset value at the previous baseline. Because current totalAssets equals the old value times (1+g), where g is the share-price growth since the last accrual, the effective charge is feeRate times profit times (1+g) rather than feeRate times profit. Independently reproduced: at feeRate 1500bps (15%) with g=10% growth on a \$10,000 vault, the treasury collects approximately \$165.00 instead of the marketed \$150.00, exactly a 16.5%-vs-15% overcharge matching the report's derivation. No fund theft or insolvency results; the excess flows to the treasury at existing depositors' expense and is bounded by accrual cadence.

Recommendation. Compute the fee base from the supply-weighted baseline asset value (lastSharePrice x totalSupply) rather than current totalAssets, applying the identical change to _feeSharesFor so pendingFeeShares() stays consistent.

Resolution. Fixed at v2.1.3 exactly as recommended; the corrected formula is present in both _accrue and _feeSharesFor, confirmed by source inspection.

F-04 Protocol reward tokens (COMP / XVS / MORPHO / Fluid) accrue to adapters and are never claimed

■ LOW

Location at v2.0.0. harvestable() hardcoded to 0 in all five adapters: CompoundV3Strategy.sol:86, VenusStrategy.sol:100, MorphoStrategy.sol:89, FluidStrategy.sol:93, AaveV3Strategy.sol:96; no claim path anywhere in BaseStrategy.sol

Every strategy adapter hardcodes harvestable() to return 0, and BaseStrategy exposes no function to claim or move non-underlying ERC-20 tokens. For Compound V3, Venus, and Morpho/MetaMorpho, protocol incentive tokens (COMP, XVS, MORPHO and related tokens) are paid as separate ERC-20 streams not reflected in the adapters' supply-position balanceOf, and because adapter state is immutable with no sweep function, any such reward token that lands on an adapter is permanently unrecoverable. Aave V3 and Fluid auto-compound their supply rate so are not affected. This is lost opportunity yield, not lost principal, and is market-dependent (frequently zero on stable USDC markets without active reward programs).

Recommendation. Add a protocol-specific claim/harvest hook in each incentivized adapter, gated to Keeper or Owner, that either swaps the reward to USDC and re-supplies it or forwards it to the vault/treasury, and implement harvestable() to report the real claimable value.

Resolution. Fixed at v2.1.3 across all five adapters via claimAndCompound plus a shared BaseStrategy swap-and-reinvest helper. The initial v2.1.0 fix required a v2.1.1 follow-up (multi-hop swap path) after a mainnet-fork probe found several reward tokens lacked deep direct-to-USDC liquidity, and further MEV-hardening (oracle floor, hop whitelist, pause propagation) was added in v2.1.2 following Soken's round-2 review (APY-2026-06-002).

F-06 Single-step Ownable (not Ownable2Step)

■ LOW

Location at v2.0.0. contracts/Vault.sol:32 (inherits Ownable), constructor init list around line 296; unpause() onlyOwner at line 874

VaultV2 uses OpenZeppelin's single-step Ownable, where transferOwnership succeeds immediately on any non-zero address with no acceptance step, and renounceOwnership is reachable and permanently sets the owner to the zero address. Because every administrative lever including unpause is onlyOwner, and the vault is immutable with no upgrade path, a mistyped transfer or an accidental or malicious renounce would permanently freeze all administrative control, which is most damaging if the guardian has paused deposits at the time. The Owner being a Gnosis Safe multi-sig (per the documented trust model) reduces the likelihood of a fat-fingered transfer, but does not eliminate the risk.

Recommendation. Inherit Ownable2Step so a transfer requires the new owner to explicitly accept, and override renounceOwnership() to revert, since an immutable yield vault should never become ownerless.

Resolution. Fixed at v2.1.3 exactly as recommended, confirmed present in source (Ownable2Step inheritance and reverting renounceOwnership override).

Informational findings and their disposition

ID	FINDING	SEVERITY	STATE AT V2.1.3
F-08	No high-water mark: depositors re-taxed across share-price round-trips	■ INFORMATIONAL	■ ACKNOWLEDGED
F-09	VenusStrategy.balanceOf() uses stale exchangeRateStored()	■ INFORMATIONAL	■ ACKNOWLEDGED

F-10	Deposit-cap grieving via direct USDC donation inflating totalAssets()	■ INFORMATIONAL	■ ACKNOWLEDGED
F-11	removeStrategy zero-balance gate uses rounding-down balanceOf()	■ INFORMATIONAL	■ ACKNOWLEDGED
F-12	USDC sent directly to an adapter is invisible to balanceOf() and permanently stranded	■ INFORMATIONAL	■ ADDRESSED
F-13	Guardian can pause deposits indefinitely; only Owner resumes (deliberate asymmetry)	■ INFORMATIONAL	■ ACKNOWLEDGED
F-14	Owner can set caps to zero, soft-freezing deposits (documented migration mechanism)	■ INFORMATIONAL	■ ACKNOWLEDGED

F-05 (an unguarded adapter view could freeze deposits and withdrawals for a future adapter) and F-15 (dead custom errors) are listed in the table above this section because both were fixed rather than accepted: v2.1 added an Owner-only quarantine flag for a misbehaving strategy, and the unused errors were removed.

05 Round two: the reward-claim surface, and its remediation

Closing F-04 required a new capability: adapters now claim protocol reward tokens and swap them back into USDC. That path is Keeper-driven and touches an external router, so it was audited as a new surface at v2.1.1. The round produced three Medium and five Low items on that path plus build-pipeline findings, and the vendor also self-identified a view-math fix. All of them were verified closed at v2.1.2, which is where the cycle reached its first PASS.

ID	WHAT WAS REQUIRED	ORIGINAL ITEM	STATE
Rec-1	On-chain Chainlink minOut floor for reward-token swaps	F-04-MEV.1, N-03	■ CLOSED
Rec-2	Intermediate-hop whitelist for multi-hop reward swaps	F-04-MEV.2, N-01, N-SP-01	■ CLOSED
Rec-3	Pause-gate the claimAndCompound path	N-02	■ CLOSED
Rec-4	Skip DEX swap when reward token equals the underlying asset	reward==underlying skip-swap	■ CLOSED
Rec-5	Owner-only rescue helper for stray idle USDC on a strategy	sweepIdleAssetToVault	■ CLOSED
Rec-6	foundry.toml via_ir flipped to true to match hardhat pipeline	M-BUILD-1, L-BUILD-1/2	■ CLOSED
Rec-7	TRUST_MODEL.md documentation of expanded Keeper power	F-04-MEV.4	■ CLOSED
Rec-8	Constructor guards: router code-size check and chain pinning	R-01, R-02	■ CLOSED
Fix-9	_convertToAssets/_convertToShares overrides account for pending fee shares	self-identified, accrue-aware view math	■ CLOSED

Residuals carried into v2.1.3

The remediation review left two Low and five Informational residuals, none of which touched principal. The residual review at v2.1.3 closed the two that were code-fixable and documented the rest inside the trust model.

ID	RESIDUAL	SEVERITY	STATE AT V2.1.3
F-901	investToStrategy / BaseStrategy.deposit are not pause-gated	■ INFORMATIONAL	■ CLOSED AT V2.1.3
F-902	Fix-9 override not bit-identical on the transactional path under a same-block accrue-latch	■ LOW	■ CLOSED AT V2.1.3

F-903	minOut floor is Owner-trust for feed-less reward tokens; staleness can DoS claims	■ LOW	■ DOCUMENTED
F-i01	TRUST_MODEL/code comments framed the minOut floor as uniformly on-chain	■ INFORMATIONAL	■ CLOSED AT V2.1.3
F-i02	_computeMinOutFloor truncates to 0 for dust amountIn; implicit USDC=\$1 assumption undocumented	■ INFORMATIONAL	■ CLOSED AT V2.1.3
F-i03	Owner reward-config setters are not onlyDeployChain	■ INFORMATIONAL	■ ACKNOWLEDGED
F-i04	BaseStrategy.sol comment states the inflate/deflate trust direction backwards	■ INFORMATIONAL	■ CLOSED AT V2.1.3

F-902 View overrides were not bit-identical on the transactional path

■ LOW

The vendor's own accrue-aware view math added the pending fee term to the supply used by the conversion helpers. On the transactional path that term should always be zero, because accrual runs first. In one window it was not: within a single block, an accrual followed by a USDC donation followed by a deposit left the pending term non-zero, which diluted the mint by approximately 2.56 percent in the reproduction.

Fix at v2.1.3. Both `_convertToAssets` and `_convertToShares` now gate the pending-fee term on the same-block accrual latch, `(lastAccruedAt == block.timestamp) ? 0 : _pendingFeeShares()`, at lines 400 and 415 of the vault. We confirmed the gate is present at both sites and that it forces zero only in the window where a fresh accrual would also mint nothing. The proof-of-concept harness quoted in the original addendum is an auditor-side artifact that was never committed to the repository, so its printed figures could not be re-run; the fix itself was verified by inspection.

F-901 A principal-in path was not pause-gated

■ INFORMATIONAL

`investToStrategy` carried `onlyKeeper nonReentrant` but not `whenNotPaused`, so a Keeper could still push idle USDC into a strategy while the Guardian had paused the vault. Low impact under a compromised Keeper, no impact otherwise.

Fix at v2.1.3. The function is now `onlyKeeper whenNotPaused nonReentrant` (vault line 922), which we confirmed both in the tag and in the deployed source on four chains. The pause matrix is now complete and self-consistent: deposit, mint and invest halt under a pause, while withdraw, redeem, divest and emergency withdrawal stay open so users and the Keeper can always exit and recover.

06 Deployment state, read on 22 September 2026

CHAIN	TIER	VAULT	VERSION HASH	PAUSED	ASSETS, USDC	SOURCE VS V2.1.3
Ethereum	Balanced	0xE46aac58214B963125a3A88541e1D BE56c4eD5f7	0x6f75c346...	no	0.0023	■ MATCH
Base	Balanced	0xeA8FB89F44A1fa47E52354D44E7e6 D4682C8529a	0x6f75c346...	no	1.2775	■ MATCH
Base	Aggressive	0x87922c630A980e431fb045A178e53 F58d3f07F85	0x5b936c82...	no	1.3109	■ MATCH
Arbitrum	Balanced	0x94f89d1E2825d40627CD2aE24Eba8 590F675049C	0x6f75c346...	no	1.0604	■ MATCH

BSC	Balanced	0x27DB5a2B203D6bd3C9490E8EA4488B968675f5Bf	0x6f75c346...	no	0.3251	■ BYTECODE ONLY
-----	----------	--	---------------	----	--------	-----------------

All five vaults hold canonical USDC for their chain, report the Owner, Keeper and Guardian addresses the project documents, and are unpaused. The Ethereum, Base and Arbitrum deployments have explorer-verified source; a line-by-line diff against the v2.1.3 tag differs only in relative import-path depth, with no logic difference across 1,076 lines. The BNB Chain deployment has no reachable source-verifier service, so its identity rests on a bytecode comparison against the verified Ethereum deployment; we record that as a bytecode-level match, not as source verification.

Items for the client's attention, found during this re-verification

ITEM	DETAIL
Owner Safe is not uniformly 2-of-3	The Safe address is identical on all four chains, but the configuration is 2-of-4 on Ethereum, Base and BNB Chain, and 2-of-3 only on Arbitrum. The project documentation describes a uniform 2-of-3.
Guardian is also an Owner signer	The Guardian key is one of the Owner Safe's signers on every chain, so it holds one vote toward the Owner threshold in addition to its unilateral pause power. Separation of the two roles is therefore partial.
Deposit caps are effectively unbounded	<code>depositCap</code> and <code>defaultUserCap</code> read <code>1e18 raw</code> on all five vaults, far above the documented per-chain and per-user limits. Both are Owner-mutable state, so this is a configuration and documentation gap rather than a code defect.
Retired generation is still live	The pre-remediation Ethereum vault <code>0xE15e10...f6eD07</code> still has code, is unpaused and holds dust of approximately 0.0005 USDC while running code without the F-17, F-01, F-02, F-901 and F-902 fixes. It is described as retired in prose but is not marked as retired on-chain or in the repository records.
Version-hash table and deployment records are stale	The published version-hash matrix lists the retired generation's hashes, and the machine-readable deployment directory the documentation links to does not exist in the repository. Only the old generation has JSON records.

07 Residual risk

- **Owner trust.** The Owner can whitelist a strategy of its own construction and route principal into it. This is inherent to a vault with a mutable strategy whitelist and no timelock, and it is the reason the score does not approach 100. It is documented in the project's trust model; a public timelock on strategy additions would reduce it.
- **Feed-less reward tokens.** For reward tokens without a price feed, the minimum-output floor on a reward swap derives from an Owner-set fallback price. Deflating that price collapses the floor, which would require Owner and Keeper to act together. The staleness guard fails closed after one day, and the residual is an operational monitoring item rather than a code defect.
- **Keeper key.** A single key drives investment and reward claims. Its reachable outcomes are bounded by the whitelist, the caps and the swap-path whitelist, but a compromised Keeper can still cause avoidable value loss inside those bounds.
- **Chain-gating of configuration setters.** Owner reward-configuration setters are not pinned to the deployment chain. Their only consumer is chain-gated, so there is no reachable replay path today; it remains a deployment-runbook item.
- **No upgrade path.** Any future fix requires a redeploy and a migration. That is a deliberate design choice and it is the reason the release discipline items in section 06 matter.

08 Corrections in this edition

This consolidated edition was produced after a full re-verification of the three published reports against the repository and the chain. No finding was withdrawn and no severity changed. The following statements were corrected.

STATEMENT IN THE ORIGINAL REPORTS	CORRECTION
Licence recorded as BUSL-1.1	The repository licence file is BUSL-1.1, but every audited Solidity file carries SPDX-License-Identifier: MIT in its own header. Since tooling and explorers read the SPDX tag, the inconsistency belongs in the report and should be resolved in the repository.
F-17 has no in-contract recovery path, only a redeploy	Overstated. A reproduction shows the Owner could clear the brick without a redeploy by whitelisting a strategy that under-reports its balance, forcing the accrual to take the loss branch, then resetting the fee rate. That is not a safe or sanctioned mechanism and it sits inside the Owner-trust boundary already disclosed, so the severity stays Critical, but the wording is softened here.
Commit hashes cited for the three remediation batches at v2.1.1	None of the three cited hashes resolve to a git object in the repository. The real commits between v2.0.0 and v2.1.1 are 7f34422 and 1efafbb. The fix content those batches describe was re-verified against real code and is accurate; the hash citations were not, and are not repeated in this edition.
The repository working head was observed to diverge from the v2.1.3 tag and to revert the pause fix	The narrow code fact holds for the commit cited, but that commit is a straight-line ancestor eighteen commits before v2.1.3, not a diverged head, and the repository's actual head carries every fix. The release-hygiene advice, that the deployment build must come from the tag or a descendant, stands without implying a live pipeline risk.
Owner is a 2-of-3 Gnosis Safe with the same address on all four chains	The address is identical on all four chains; the threshold is 2 but there are four signers on three of them, so the configuration is 2-of-4 on Ethereum, Base and BNB Chain and 2-of-3 only on Arbitrum.
F-902 closure evidenced by a quoted proof-of-concept run	The harness is an auditor-side artifact that was never committed to the repository, so its printed numbers cannot be reproduced by a third party. The closure is evidenced here by direct inspection of the gate in both view overrides. Future rounds should commit the harness alongside the code.

09 Disclaimer

This report was prepared by SOKEN LTD (Companies House 15253906). It consolidates three audit rounds performed in June and July 2026 on the source code identified in section 02 at the tags stated, and a re-verification of that work performed on 22 September 2026 against the public repository and the live deployments. A security review is a point-in-time assessment of the code in scope and is not a guarantee that the code is free of defects, nor an endorsement of the project, its economics or its operators. Scores are our internal scale and are not comparable across auditors. Items in section 06 describe the state of on-chain configuration on the date of reading; on-chain values change, so re-read any figure at the linked address before relying on it. Off-chain key management, operational practice, the front end and third-party protocol risk are outside the scope of this review. Nothing in this document is financial, investment or legal advice.